RAPID7

Vulnerability Disclosure

Baxter SIGMA Spectrum Infusion Pumps: Multiple Vulnerabilities (FIXED)



Deral Heiland

Sep 8, 2022 | Last updated on Sep 8, 2022 | 8 min read

Product description

Product description

Credit

Vendor statement

Exploitation and remediation

Battery unit's battery (firmware versions 16, 17, 20, 22)

Format string vulnerabilities

Unauthenticated network reconfiguration via TCP/UDP (CVE-2022-26394)

UART configuration access to Wi-Fi configuration data (additional finding)

Disclosure timeline

Product description

Rapid7, Inc. (Rapid7) discovered vulnerabilities in two TCP/IP-enabled medical devices produced by Baxter Healthcare. The affected products are:

- SIGMA Spectrum Infusion Pump (Firmware Version 8.00.01)
- SIGMA Wi-Fi Battery (Firmware Version 16.17.20.3929)

Rapid7 initially reported these issues to Baxter on April 20, 2022. Since then, members of our research team have worked alongside the vendor to discuss the impact, resolution, and a coordinated response for these vulnerabilities.

Product description

Baxter's SIGMA Spectrum product is a commonly used brand of infusion pumps, which are typically used by hospitals to deliver medication and nutrition directly into a patient's circulatory system. These TCP/IP-enabled devices deliver data to healthcare providers to enable more effective, coordinated care.

Credit

The vulnerabilities in two TCP/IP-enabled medical devices were discovered by Deral Heiland, Principal IoT Researcher at Rapid7. They are being disclosed in accordance with Rapid7's vulnerability disclosure policy after coordination with the vendor.

"In support of our mission to save and sustain lives, Baxter takes product security seriously. We are committed to working with the security researcher community to verify and respond to legitimate vulnerabilities and ask researchers to participate in our responsible reporting process. Software updates to disable Telnet and FTP (CVE-2022-26392) are in process. Software updates to address the format string attack (CVE-2022-26393) are addressed in WBM version 20D30 and all other WBM versions. Authentication is already available in Spectrum IQ (CVE-2022-26394). Instructions to erase all data and settings from WBMs and pumps before decommissioning and transferring to other facilities (CVE-2022-26390) are in process for incorporation into the Spectrum Operator's Manual and are available in the Baxter Security Bulletin."

Exploitation and remediation

This section details the potential for exploitation and our remediation guidance for the issues discovered and reported by Rapid7, so that defenders of this technology can gauge the impact of, and mitigations around, these issues appropriately.

Battery units store Wi-Fi credentials (CVE-2022-26390)

Rapid7 researchers tested Spectrum battery units for vulnerabilities. We found all units that were tested store Wi-Fi credential data in non-volatile memory on the device.

When a Wi-Fi battery unit is connected to the primary infusion pump and the infusion pump is powered up, the pump will transfer the Wi-Fi credential to the battery unit.

Exploitation

An attacker with physical access to an infusion pump could install a Wi-Fi battery unit (easily purchased on eBay), and then quickly power-cycle the infusion pump and remove the Wi-Fi battery – allowing them to walk away with critical Wi-Fi data once a unit has been disassembled and reverse-engineered.

Also, since these battery units store Wi-Fi credentials in non-volatile memory, there is a risk that when the devices are de-acquisitioned and no efforts are made to overwrite the stored data, anyone acquiring these devices on the secondary market could gain access to critical Wi-Fi credentials of the organization that de-acquisitioned the devices.

To mitigate this vulnerability, organizations should restrict physical access by any unauthorized personnel to the infusion pumps or associated Wi-Fi battery units.

In addition, before de-acquisitioning the battery units, batteries should be plugged into a unit with invalid or blank Wi-Fi credentials configured and the unit powered up. This will overwrite the Wi-Fi credentials stored in the non-volatile memory of the batteries. Wi-Fi must be enabled on the infusion pump unit for this overwrite to work properly.

Format string vulnerabilities

“Hostmessage” (CVE-2022-26392)

When running a telnet session on the Baxter Sigma Wi-Fi Battery Firmware Version 16, the command “hostmessage” is vulnerable to format string vulnerability.

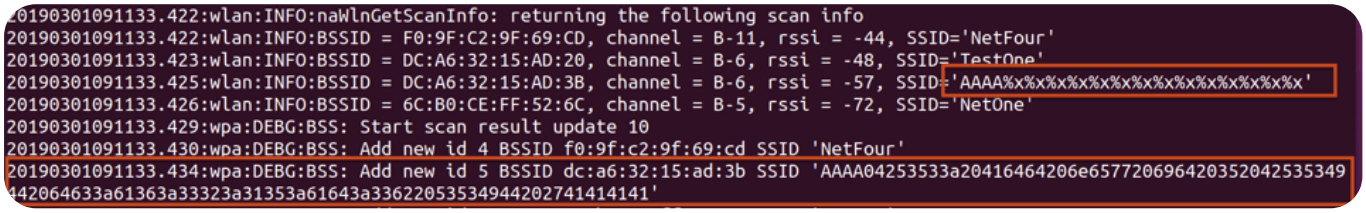
Exploitation

An attacker could trigger this format string vulnerability by entering the following command during a telnet session:

```
hostmessage AAAA %x %x %x
```

Exploitation

This format string vulnerability can be triggered by first setting up a Wi-Fi access point containing format string specifiers in the SSID. Next, an attacker could send a *`get_wifi_location (20)`* command via TCP Port 51243 or UDP port 51243 to the infusion pump. This causes the device to process the SSID name of the access point nearby and trigger the exploit. The results of the triggering of format strings can be viewed with trace log output within a telnet session as shown below.



The SSID of *`AAAA%x%x%x%x%x%x%x%x%x%x%x%x%x%x`* allows for control of 4 bytes on the stack, as shown above, using the *`%x`* to walk the stack until it reaches 41414141. By changing the leading *`AAAA`* in the SSID, a malicious actor could potentially use the format string injection to read and write arbitrary memory. At a minimum, using format strings of *`%s`* and *`%n`* could allow for a denial of service (DoS) by triggering an illegal memory read (*`%s`*) and/or illegal memory write (*`%n`*).

Note that in order to trigger this DoS effect, the attacker would need to be within normal radio range and either be on the device's network or wait for an authorized *`get_wifi_location`* command (the latter would itself be a usual, non-default event).

Remediation

To prevent exploitation, organizations should restrict access to the network segments containing the infusion pumps. They should also monitor network traffic for any unauthorized host communicating over TCP and UDP port 51243 to infusion pumps. In addition, be sure to monitor Wi-Fi space for rogue access points containing format string specifiers within the SSID name.

Unauthenticated network reconfiguration via TCP/UDP (CVE-2022-26394)

All Wi-Fi battery units tested (versions 16, 17, and 20 D29) allowed for remote unauthenticated changing of the SIGMA GW IP address. The SIGMA GW setting is used for configuring the back-end communication services for the devices operation.

Exploitation

changeable using this command. An example of this command and associated structure is shown below:

```
Serial number: 1234567
Command set_net_config: 15
Device ID: ABC123
SIGMA GW IP address: 192.168.4.115

<HEADER>1.0,1234567,20190224093805,510010146,15,ABC123</HEADER>
1,192.168.4.100,192.168.4.1,255.255.255.0,192.168.4.1,192.168.4.102,0.0.0.0,ABC123,00:40:9
d:90:c1:bd,51243,20190224100556 </XML
```

This could be used by a malicious actor to man-in-the-middle (MitM) all the communication initiated by the infusion pump. This could lead to information leakage and/or data being manipulated by a malicious actor.

Remediation

Organizations using SIGMA Spectrum products should restrict access to the network segments containing the infusion pumps. They should also monitor network traffic for any unauthorized host communicating over TCP and UDP port 51243 to the infusion pumps.

UART configuration access to Wi-Fi configuration data (additional finding)

The SIGMA Spectrum infusion pump unit transmits data unencrypted to the Wi-Fi battery unit via universal asynchronous receiver-transmitter (UART). During the power-up cycle of the infusion pump, the first block of data contains the Wi-Fi configuration data. This communication contains the SSID and 64-Character hex PSK.

New Open Save Connect Disconnect Clear Data Options View Hex Help
<B>?</B>YC<B>NO</B>∏\<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<B>?</B>YC<XML><HEADER>1.0,2050662,20211007191200,2163363392000,22,N13570</HEADER>v8.00.01,1,3010692091,0, LIB 09-15-20(45),4/20/2011 9:34:22 PM,09/15/2020,09/15/2020,99b3</XML>])<XML><HEADER>1.0,2050662,20211007191200,2163363392001,15,N13570</HEADER>1,0.0.0.0,0.0.0.0,0.0.0.0,0.0.0.0,baxterpumps,0.0.0.0,0.0.0.0,N13570,,,</XML>aÆ<XML><HEADER>1.0,2050662,20211007191200,2163363392002,28,N13570</HEADER>0,</XML>.,<XML><HEADER>1.0,2050662,20211007191200,2163363392003,18,N13570</HEADER>0,dev2,0,3,0,,3,a12245cc84d34ed97a8eb5b08281e54b381fb02028bf9e273b498f7a859517e7,0,,,3,,,,0</XML>©Y<B>?</B>YC

Exploitation

A malicious actor with **physical access** to an infusion pump can place a communication shim between the units (i.e., the pump and the Wi-Fi battery) and capture this data during the power-up cycle of the unit.



Remediation

To help prevent exploitation, organizations should restrict physical access by unauthorized persons to the infusion pumps and associated Wi-Fi battery units.

Note that this is merely an additional finding based on physical, hands-on access to the device. While Baxter has addressed this finding through better decommissioning advice to end users, this particular issue does not rank for its own CVE identifier, as local encryption is beyond the scope of the hardware design of the device.

Disclosure timeline

Baxter is an exemplary medical technology company with an obvious commitment to patient and hospital safety. While medtech vulnerabilities can be tricky and expensive to work through, we're quite pleased with the responsiveness, transparency, and genuine interest shown by Baxter's product security teams.

- **April, 2022:** Issues discovered by Deral Heiland of Rapid7
- **Wed, April 20, 2022:** Issues reported to Baxter product security
- **Wed, May 11, 2022:** Update requested from Baxter
- **Wed, Jun 1, 2022:** Teleconference with Baxter and Rapid7 presenting findings
- **Jun-Jul 2022:** Several follow up conversations and updates between Baxter and Rapid7
- **Tue, Aug 2, 2022:** Coordination tracking over VINCE and more teleconferencing involving Baxter, Rapid7, CERT/CC, and ICS-CERT (VU#142423)
- **Wed, Aug 31, 2022:** Final review of findings and mitigations
- **Thu Sep 8, 2022:** Baxter advisory published
- **Thu, Sep 8, 2022:** Public disclosure of these issues
- **Thu, Sep 8, 2022:** ICS-CERT advisory published

Additional reading:

- *Rapid7 Discovered Vulnerabilities in Cisco ASA, ASDM, and FirePOWER Services Software*
- *CVE-2022-31660 and CVE-2022-31661 (FIXED): VMware Workspace ONE Access, Identity Manager, and vRealize Automation LPE*
- *QNAP Poisoned XML Command Injection (Silently Patched)*
- *Primary Arms PII Disclosure via IDOR (FIXED)*

Article tags

Vulnerability Disclosure | Research | IoT

Continue reading



VULNERABILITIES AND EXPLOITS

When Business Email Compromise Starts Rewriting Reality



Douglas McKee, Director, Vulnerability



VULNERABILITIES AND EXPLOITS

CVE-2026-86206, CVE-2026-86207: N-able N-central Authentication Bypass (FIXED)





VULNERABILITIES AND EXPLOITS

Rapid7 Analysis: Microsoft SharePoint JWT Token Authentication Bypass (CVE-2026-55040)



Explore more from Rapid7

Vulnerability & Exploit Database

Rapid7s curated database of vulnerabilities, featuring exploit modules and check methods integrated into the Metasploit Framework.

Search The Database →

Rapid7 Labs

The threat research behind the alerts: adversary tracking, curated intelligence, and flagship threat reports.

Explore The Research →

Rapid7 MDR

Gain 24×7 XDR monitoring, remediation, and DFIR from experts that extend your

Exposure management

Get continuous assessment of your attack surface with the critical context to validate

Explore MDR →

See How It Works →

GET STARTED

- Command Platform
- Exposure Management
- MDR Services
- Solutions

TAKE ACTION

- Start a Free Trial
- Take a Product Tour
- Get Breach Support
- Contact Sales

STAY INFORMED

- Blog
- Emergent Threat Response
- Webinars & Events
- Rapid7 Labs Research
- Vulnerability Database
- Security Fundamentals

CONTACT SUPPORT

+1-866-390-8113

COMPANY

- About Us
- Leadership
- Newsroom
- Our Customers
- Partner Programs
- Investors
- Careers

FOR CUSTOMERS

- Sign In
- Support Portal
- Product Documentation
- Extension Library
- Rapid7 Academy
- Customer Escalation Portal

FOLLOW US

- LinkedIn
- X (Twitter)
- Facebook
- Instagram
- Bluesky

© Rapid7 Legal Terms Privacy Policy Export Notice Trust Cookie List Accessibility Statement